

Chapter 2 (Version 2)

Federal Identity, Credential, and Access Management (FICAM): Identity Governance, Defense, and Mission-Essential Environments

The current charter locks Chapter 2 as the governance foundation for federal identity security and places technical architecture in Chapter 3. Its first narrative section is **2.1 Governance Before Technology**.

2.1 Governance Before Technology

Identity infrastructure is often approached as a deployment problem. An agency selects a directory platform, issues smart cards, enables Multi-Factor Authentication (MFA), connects applications to an Identity Provider (IdP), and introduces a Privileged Access Management (PAM) system. Each project may satisfy an immediate technical requirement, yet the resulting environment can still lack a coherent answer to the central question of identity security:

Who or what should be trusted, for which purpose, under whose authority, and for how long?

Technology cannot answer that question by itself. Active Directory Domain Services (AD DS) can store an account and enforce group membership, but it cannot determine whether the person represented by that account still requires access. A Public Key Infrastructure (PKI) can issue a certificate, but it cannot establish the mission justification for the credential. A federation service can transmit an identity assertion, but it cannot decide whether the issuing authority should be trusted for a particular transaction. Microsoft Entra ID can enforce an access policy, but the platform cannot independently determine whether the attributes, roles, devices, and exceptions used by that policy reflect current mission requirements.

Those are governance decisions.

Federal Identity, Credential, and Access Management (FICAM) provides the government-wide structure through which agencies design, plan, and execute common Identity, Credential, and Access Management (ICAM) processes. The FICAM Architecture describes identity management, credential management, and access management as interconnected practice areas supported by federation and governance. It allows agencies to adapt those practices to their distinct missions while maintaining alignment with federal security, privacy, and interoperability objectives. ([IdManagement.gov](https://www.idmanagement.gov))

FICAM is not a Microsoft product architecture. It does not prescribe one directory platform, certificate authority, federation service, cloud provider, or privileged-access product. It defines the governance and trust requirements that those technologies must implement.

2.1.1 Identity Systems Enforce Decisions Made Elsewhere

An identity platform usually receives its most consequential inputs from outside the platform itself.

A personnel system establishes that an individual has entered federal service. A contracting process identifies an approved contractor and sponsoring authority. A mission owner determines which duties require access. A security office establishes restrictions. An application owner defines roles. A Credential Service Provider conducts or relies upon identity proofing and binds authenticators to the established identity. Administrators then implement the resulting decisions through accounts, attributes, groups, certificates, roles, policies, and technical entitlements.

The directory is an enforcement point within this chain, not the sole source of truth for every decision.

This distinction becomes visible when information disagrees. The personnel system may show that an employee transferred to another command while the directory still reflects the former assignment. A contractor's period of performance may have ended while the account remains enabled. An application role may have changed while the corresponding security group retains its previous membership. A certificate may remain valid after the access need associated with it has disappeared.

The technology continues enforcing the information it possesses. It cannot recognize that the underlying mission decision has changed unless the governance process communicates that change accurately and promptly.

An account can be technically valid and operationally unauthorized at the same time.

Identity governance addresses that gap by establishing authoritative sources, decision rights, lifecycle events, ownership, approval requirements, review intervals, revocation procedures, and accountability. It determines which system is authoritative for an attribute, which office approves a role, who may sponsor an external identity, and which event should trigger access removal.

Without those rules, the identity platform becomes a collection point for accumulated decisions that no one can fully explain.

2.1.2 The Tool-First Failure Pattern

Tool-first identity programs often appear successful during initial deployment. Accounts are synchronized. MFA prompts appear. dashboards show enrollment totals. Applications begin accepting federated authentication. Privileged passwords move into a vault.

The weaknesses emerge later.

No single authority owns the complete identity lifecycle. Personnel data, contractor data, directory attributes, access requests, certificates, application roles, privileged accounts, and cloud identities are maintained through separate processes. Each team can explain its own platform, but no one can trace the complete path from identity establishment to access revocation.

Duplicate identities appear because several systems create accounts independently. Group membership grows through repeated access requests without corresponding removal. Service

identities remain active after the applications they supported have been retired. Privileged access is granted as a permanent entitlement because the workflow cannot support temporary elevation. Federation relationships are enabled for interoperability but never reevaluated after the mission arrangement changes.

The technology has not necessarily malfunctioned. It is faithfully enforcing fragmented governance.

This pattern is especially dangerous in hybrid environments. An identity may originate in one authoritative source, be provisioned into AD DS, synchronized into Microsoft Entra ID, mapped to a cloud application, assigned to a privileged role, and represented by certificates or tokens accepted elsewhere. An inaccurate attribute or stale entitlement can propagate through several systems before anyone recognizes its effect.

Adding another security product may increase visibility or strengthen one control. It does not repair uncertainty about ownership, authority, or lifecycle.

The first corrective action is to reconstruct the decision chain:

- Which source establishes the identity?
- Who sponsors or owns it?
- Which attributes are authoritative?
- Who approves access?
- Which systems consume that approval?
- What event changes or terminates the access?
- Who verifies that revocation reached every connected platform?

These are governance questions expressed through technical dependencies.

2.1.3 Governance Establishes the Conditions of Trust

Trust in an identity system is conditional. It depends on the quality of the identity proofing process, the strength and management of the authenticator, the integrity of identity attributes, the authority of the issuer, the security of the communication path, and the receiving system's authorization decision.

No single credential answers every question.

A Personal Identity Verification (PIV) card or Common Access Card (CAC) may provide strong cryptographic authentication, but the relying system still needs to determine what the authenticated identity may access. A federation assertion may originate from an approved IdP, yet the Relying Party (RP) must evaluate whether the assertion is appropriate for the requested

transaction. A directory account may be valid, while its group membership grants access beyond the person's current duties.

Governance defines the conditions under which each form of evidence may be accepted.

NIST Special Publication (SP) 800-63-4 and its companion volumes separate digital identity assurance into identity proofing, authentication, and federation. The current Revision 4 suite covers the processes and technical requirements associated with Identity Assurance Levels (IALs), Authenticator Assurance Levels (AALs), and Federation Assurance Levels (FALs). These dimensions address different risks and should not be treated as interchangeable measures of one generalized "identity strength." ([NIST Computer Security Resource Center](#))

An identity may have been established through a rigorous proofing process while using an authenticator that is unsuitable for a high-risk transaction. A strong authenticator does not correct weak identity proofing. A well-protected federation assertion does not guarantee that the Relying Party has assigned appropriate authorization.

The assurance decision belongs to the transaction and its risk, not to the product alone.

Governance connects those dimensions to mission need. It identifies the potential harm caused by an identity error, authenticator compromise, or federation failure and selects controls consistent with that risk. It also determines which exceptions may be accepted, who has authority to approve them, how long they remain valid, and what compensating controls are required.

This is where policy becomes operational. The agency is not declaring that identity should be secure in the abstract. It is specifying the evidence required before a particular identity can perform a particular action against a particular resource.

2.1.4 Governance Is an Operational Control, Not a Documentation Exercise

Governance is sometimes reduced to policies, diagrams, approval signatures, and recurring access-review campaigns. Those artifacts are useful only when they influence actual identity behavior.

A governance process is functioning when an authoritative change causes the appropriate technical response. A separation event disables access quickly enough to reduce exposure. A transfer removes permissions associated with the previous assignment. A privileged role expires when the approved period ends. A compromised authenticator can be revoked without leaving alternate access paths active. A mission-partner relationship can be constrained or suspended without requiring improvised directory changes during an incident.

Documentation supports those outcomes. It is not a substitute for them.

An agency may possess a formally approved access-control policy while maintaining thousands of unowned groups. It may require periodic reviews while providing reviewers with incomplete

information about nested membership or application mappings. It may mandate rapid termination while relying on disconnected manual processes that take days to reach every system.

The written requirement and the operational capability are different forms of evidence.

A credible identity governance program should be able to demonstrate how policy becomes enforcement. That includes showing how an approved role is represented in the directory, how the role reaches applications, how privileged access is constrained, how changes are logged, how exceptions are tracked, and how access is removed.

The proof lies in the complete lifecycle, not in one configuration screenshot.

2.1.5 Mission Ownership and Technical Ownership

Identity governance crosses administrative boundaries because no single technical team owns every decision involved.

Human resources may own personnel status. Contracting and program offices may own contractor sponsorship. Security offices define control requirements. Application owners determine what access supports the mission. Identity teams operate directories, provisioning systems, and federation services. PKI teams issue and manage certificates. Privileged-access teams govern elevated credentials. Security Operations Centers monitor identity activity. System owners remain accountable for the access accepted by their systems.

These responsibilities must connect without collapsing into one undifferentiated authority.

A directory administrator should not decide independently that a contractor requires access to a mission application. An application owner should not be able to bypass identity proofing or credential requirements because access is operationally urgent. A security office should not define controls without understanding whether the identity infrastructure can enforce them. A help-desk operator should not be granted broad authority simply because the current workflow cannot distinguish routine support from privileged identity administration.

Separation of duties protects the legitimacy of the decision chain.

It also creates coordination requirements. When roles are unclear, each team assumes another group is validating the request. The sponsor believes the application owner reviewed the access. The application owner believes the identity team verified the sponsor. The identity team assumes the authoritative source already established eligibility.

The account is created, but no one owns the complete decision.

Governance assigns that ownership explicitly. It identifies who may request, approve, provision, review, modify, suspend, and revoke access. It also defines which combinations of authority must remain separated.

2.1.6 Governance of Person and Non-Person Entities

Federal identity governance must address more than employees, military personnel, contractors, and mission partners. Applications, services, devices, workloads, automated agents, and other Non-Person Entities (NPEs) also authenticate and exercise authority.

The lifecycle of an NPE differs from that of a person.

A service account does not undergo personnel onboarding. A workload cannot attest to its own mission need. An application does not receive a termination notice when its original owner leaves. The legitimacy of the identity must be established through system ownership, approved architecture, configuration management, credential issuance, deployment records, and continuing operational need.

This makes ownership indispensable.

Every NPE should be traceable to an accountable mission or system owner. Its purpose, authentication method, permitted locations, dependencies, privileges, credential-management process, monitoring requirements, and retirement conditions must be known. Without that information, the identity can persist indefinitely because no team is confident that it can be disabled safely.

Machine identities frequently become some of the longest-lived and least-governed principals in the enterprise. They may operate continuously, hold broad access, and authenticate across many systems without generating the behavioral signals associated with human activity.

Governance must compensate for that difference through tighter scoping, technical attestation, predictable use patterns, automated credential management where supported, and explicit lifecycle controls.

2.1.7 The Governance-to-Technology Chain

FICAM and ICAM do not compete with Active Directory, Microsoft Entra ID, PKI, federation, or PAM. They provide the decision structure those technologies operationalize.

The relationship can be followed from policy to enforcement:

A mission requirement establishes a need for access. Governance identifies the responsible authority and the risk associated with the transaction. Identity proofing establishes confidence in the claimed identity. Credential management binds an approved authenticator to that identity. Access management evaluates authentication and authorization requirements. Federation extends selected trust to separately administered systems. Technical platforms implement the accounts, attributes, credentials, groups, roles, policies, assertions, and logs required to support the decision.

The quality of the final access decision depends on every link.

A secure directory cannot correct an invalid sponsorship decision. Strong MFA cannot correct excessive authorization. A properly signed federation assertion cannot correct inaccurate attributes. A sophisticated PAM platform cannot protect privileged roles that were never identified as privileged. Continuous monitoring cannot provide meaningful evidence when identities lack owners and expected behavior has never been defined.

Governance gives technical controls their context.

That context is particularly important during compromise. An agency must know which identities can be disabled immediately, which mission functions depend on them, which alternate credentials remain valid, which partners accept their assertions, and which authorities can approve emergency replacement access. Decisions that were never established during normal operations become difficult to invent under incident pressure.

Governance before technology does not mean delaying technical improvement until every policy is perfect. It means that each technical control should implement a known trust decision, serve an accountable mission purpose, and produce evidence that the decision remains valid.

FICAM provides the federal governance lens. ICAM programs translate that lens into agency and departmental operations. Active Directory, cloud identity, PKI, federation, PAM, and authentication platforms enforce the resulting decisions.

The infrastructure can only be as trustworthy as the governance that gives it authority.